Національний технічний університет України
«Київський політехнічний інститут імені Ігоря Сікорського»
Факультет інформатики та обчислювальної техніки
Кафедра інформатики та програмної інженерії

ЗВІТ

з лабораторної роботи № 1

«Побудова моделі загроз програмного застосунку»

з дисципліни «Безпека програмного забезпечення»

Варіант 29

Виконав(ла):
здобувач(ка) групи ІП-33
Шульга Нікіта Сергійович

Перевірив:
Соколовський Владислав
Володимирович

Київ — 2026

1 МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи — набути практичних навичок систематичного передпроєктного аналізу захищеності програмного застосунку через побудову його моделі загроз, кількісне оцінювання виявлених загроз та обґрунтоване планування контрзаходів.

Завдання: описати активи системи й побудувати DFD з межами довіри; застосувати STRIDE до кожного елемента діаграми (не менше 12 загроз); оцінити загрози за CVSS і визначити не менше трьох загроз високого ризику; побудувати дерево атак для найкритичнішої загрози; сформувати реєстр ризиків; обґрунтувати пріоритетність усунення загроз.

Індивідуальний варіант 29 (отримано командою python -m common.variants 29 --lab 1):

```
Варіант 29

  LAB1
    system: мобільний застосунок обліку особистих фінансів
    focus_category: підміна даних (Tampering)
    min_threats: 12
    min_high_risk: 3
```

Об’єкт моделювання — мобільний застосунок обліку особистих фінансів; пріоритетна категорія STRIDE — підміна даних (Tampering); кількісні вимоги — не менше 12 загроз, з них не менше 3 з базовою оцінкою CVSS ≥ 7,0.

2 ТЕОРЕТИЧНІ ВІДОМОСТІ

Модель загроз будується до написання коду, бо усунення проєктного недоліку на етапі проєктування коштує на порядки дешевше, ніж після розгортання [1, 5]. Для системи FinTrack це особливо важливо: архітектура offline-first переносить створення даних на пристрій користувача, тобто в зону, яку власник системи не контролює.

Аналіз виконано методом STRIDE-per-element [1]: до зовнішніх сутностей застосовано категорії S і R, до процесів — усі шість, до сховищ — T, I, D (R — лише для журналу аудиту DS4), до потоків — T, I, D. Пріоритетна категорія варіанта — Tampering (порушення цілісності), тому для кожного процесу, сховища й потоку, що перетинає межу довіри, окремо перевірено можливість несанкціонованої зміни даних.

Кожну загрозу оцінено базовою метрикою CVSS v3.1 [2] за допомогою калькулятора cvss.py. Для впорядкування в межах однакових оцінок додатково застосовано якісну матрицю «ймовірність × вплив» зі шкалою B = 3, C = 2, H = 1: добуток 9 — критичний, 6 — високий, 3–4 — середній, 1–2 — низький ранг. Ймовірність оцінено експертно з урахуванням поширеності техніки атаки (CAPEC [4]) і того, чи потрібні для неї фізичний доступ або привілеї.

Для найкритичнішої загрози побудовано дерево атак із вузлами AND/OR. Для захисника вузол AND вигідніший: щоб зупинити атаку, достатньо перекрити одну дочірню гілку, тоді як для вузла OR потрібно перекрити всі. Рішення в реєстрі ризиків приймалися за чотирма стратегіями: усунути, зменшити, передати, прийняти.

3 ОПИС СИСТЕМИ ТА АКТИВИ

Об’єкт моделювання — вигадана навчальна система FinTrack: мобільний застосунок обліку особистих фінансів для Android та iOS із хмарною синхронізацією. Користувач вручну вносить доходи й витрати, розподіляє їх за категоріями, веде бюджети (зокрема спільний сімейний бюджет кількох облікових записів) і переглядає звіти. Транзакції можна також імпортувати автоматично з банку через Open Banking API або з файла виписки у форматі CSV.

Застосунок працює за принципом offline-first: усі записи спочатку зберігаються в локальній базі даних на пристрої, а потім пакетами синхронізуються з хмарним бекендом через HTTPS REST API з автентифікацією за JWT. Бекенд складається з API-шлюзу, сервісу синхронізації та сервісу імпорту банківських транзакцій, який отримує від банку webhook-сповіщення про нові операції. Дані зберігаються в PostgreSQL, події безпеки — в окремому журналі аудиту, щоденні дампи БД — в об’єктному сховищі резервних копій.

Користувачі: власник облікового запису; учасники спільного бюджету; адміністратор бекенду (обслуговування, без доступу до бізнес-функцій). Зовнішні служби: Open Banking API банку-партнера; магазини застосунків (канал поширення). Застосунок не ініціює платежів — він лише обліковує операції, тому головна цінність системи — достовірність фінансової історії та її конфіденційність. Усі дані в моделі синтетичні.

Активи системи та їхню цінність за властивостями конфіденційності, цілісності й доступності (В — висока, С — середня, Н — низька) наведено в таблиці 3.1.

Таблиця 3.1 – Активи системи FinTrack

ID	Актив	Тип	К/Ц/Д
A1	Історія фінансових транзакцій і баланси рахунків	дані (DS1, DS3)	В/В/С
A2	Облікові дані користувачів (хеші паролів, PIN)	дані автентифікації	В/В/С
A3	Токени доступу (JWT, refresh-токени, OAuth2-токени Open Banking)	секрети сесії	В/В/С
A4	Криптографічні ключі (ключ шифрування локальної БД, секрет підпису webhook)	секрети	В/В/С

ID	Актив	Тип	К/Ц/Д
A5	Журнал аудиту дій користувачів і сервісів	журнал подій	С/В/С
A6	Резервні копії хмарної БД	дані	В/В/С
A7	Цілісність коду мобільного застосунку (APK/IPA)	програмне забезпечення	Н/В/С
A8	Доступність сервісу синхронізації	послуга	Н/С/С

Серед активів високу конфіденційність мають A1–A4 і A6, високу цілісність — A1–A7. Найціннішим є A1: для обліку фінансів спотворена історія операцій так само шкідлива, як і її витік.

4 ДІАГРАМА ПОТОКІВ ДАНИХ

DFD системи (рисунок 4.1) побудовано в нотації Mermaid (файл dfd.mmd, лістинг — у додатку А). Компоненти згруповано в три межі довіри: МД1 — мобільний пристрій користувача (недовірена для бекенду зона), МД2 — хмарний бекенд, МД3 — зона зберігання даних, доступна лише сервісам бекенду.

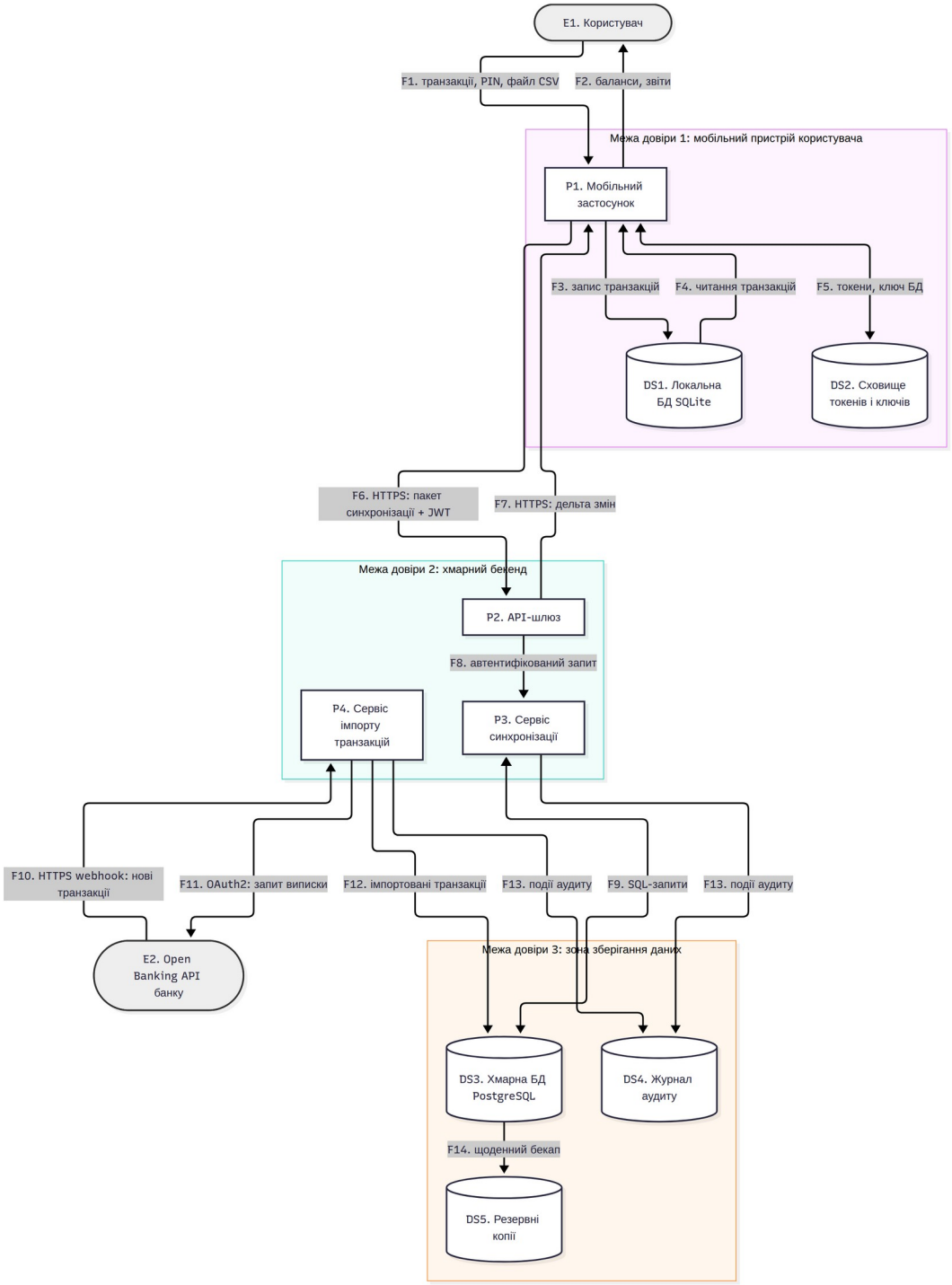


Рисунок 4.1 – Діаграма потоків даних системи FinTrack

Таблиця 4.1 – Елементи DFD

Позначення	**Елемент**	**Тип**	**Межа довіри**
E1	Користувач	зовнішня сутність	поза межами
E2	Open Banking API банку	зовнішня сутність	поза межами
P1	Мобільний застосунок	процес	МД1
DS1	Локальна БД SQLite	сховище	МД1
DS2	Сховище токенів і ключів	сховище	МД1
P2	API-шлюз	процес	МД2
P3	Сервіс синхронізації	процес	МД2
P4	Сервіс імпорту транзакцій	процес	МД2
DS3	Хмарна БД PostgreSQL	сховище	МД3
DS4	Журнал аудиту	сховище	МД3
DS5	Резервні копії	сховище	МД3

Таблиця 4.2 – Потоки даних, що перетинають межі довіри

Потоки	**Між елементами**	**Перетинає межу**
F1, F2	E1 ↔ P1	зовнішня сутність → МД1
F6, F7	P1 ↔ P2	МД1 → МД2 (через інтернет)
F9, F12, F13	P3, P4 → DS3, DS4	МД2 → МД3
F10, F11	E2 ↔ P4	зовнішня сутність → МД2

Саме ці потоки стали основним джерелом загроз: дані з менш довіреної зони потрапляють у більш довірену, і кожен такий вхід потребує перевірки автентичності та цілісності.

5 ЗАГРОЗИ ЗА STRIDE

Діаграму пройдено елемент за елементом. Отримано 15 загроз (таблиця 5.1); ідентифікатор загрози починається з літери її категорії STRIDE.

Таблиця 5.1 – Перелік загроз за STRIDE

№	Елемент / потік	Категорія STRIDE	Опис загрози	Порушувана властивість
T-01	F6/F7 (P1 ↔ P2)	Tampering	Модифікація пакета синхронізації в транзиті: зловмисник у тій самій Wi-Fi-мережі виконує атаку «людина посередині»; застосунок довіряє сертифікатам центрів сертифікації, встановленим користувачем, і не використовує certificate pinning, тому суми й категорії транзакцій змінюються до надходження на сервер.	цілісність
T-02	DS1 Локальна БД SQLite	Tampering	Пряма зміна нешифрованого файла SQLite на рутованому пристрої або через резервну копію ADB (android:allowBackup="true"): змінюються суми, дати й баланси; змінені записи синхронізуються в хмару як легітимні.	цілісність
T-03	P3 Сервіс синхронізації (F8)	Tampering	Масове присвоєння полів (mass assignment): сервіс зберігає об’єкт транзакції з пакета «як є», зокрема поля balance_after, owner_id і created_at; модифікований клієнт перезаписує обчислений баланс рахунку й дату операції.	цілісність
T-04	F10 (E2 → P4)	Tampering	Підроблені webhook-сповіщення: ендпоінт /webhooks/bank приймає повідомлення про нові транзакції без перевірки HMAC-підпису та позначки часу; будь-хто, кому відома адреса ендпоінта, вносить фіктивні транзакції в історію користувача.	цілісність
T-05	F9 (P3 → DS3)	Tampering	SQL-ін’єкція в параметрах фільтра пошуку транзакцій (q, sort): рядок конкатенується в SQL-запит, що дозволяє виконати UPDATE/DELETE над записами будь-яких користувачів у DS3.	цілісність (також конфіденційність, доступність)
T-06	P1 Мобільний застосунок	Tampering	Репакування застосунку: модифікований APK з неофіційного джерела містить вбудований код, що змінює суми в пакетах синхронізації та пересилає токени зловмисникові; сервер не перевіряє цілісність клієнта.	цілісність
T-07	DS4 Журнал аудиту	Tampering	Обліковий запис сервісів має права UPDATE/DELETE на таблицю аудиту; зловмисник, що отримав доступ до P3, видаляє або змінює записи про свої дії й	цілісність (неспростовність)

№	Елемент / потік	Категорія STRIDE	Опис загрози	Порушувана властивість
			приховує підміну даних.	
T-08	F6 (P1 → P2)	Tampering	Повторне відтворення (replay) перехопленого чи збереженого пакета синхронізації: без ідентифікаторів змін і контролю версій це дублює транзакції або відкочує баланс до попереднього стану.	цілісність
S-09	E1 Користувач (вхід через P2)	Spoofing	Credential stuffing: перебір пар «логін — пароль» з чужих витоків на ендпоінті /auth/login без обмеження частоти спроб і другого фактора; зловмисник видає себе за власника облікового запису.	автентичність
S-10	E1 / P1 (локальний вхід)	Spoofing	Обхід локальної автентифікації на викраденому пристрої: 4-значний PIN без обмеження кількості спроб дозволяє сторонній особі відкрити застосунок від імені власника.	автентичність
R-11	E1 Користувач (спільний бюджет)	Repudiation	Учасник спільного бюджету заперечує видалення чи зміну витрати: зміни фіксуються без прив’язки до автора й пристрою, тому неможливо довести, хто виконав дію.	неспростовність
I-12	DS2 Сховище токенів і ключів	Information disclosure	Refresh-токен і ключ шифрування БД зберігаються в SharedPreferences у відкритому вигляді й потрапляють у системний журнал (logcat); застосунок із root-доступом або резервна копія пристрою розкривають їх.	конфіденційність
I-13	DS5 Резервні копії	Information disclosure	Помилка конфігурації об’єктного сховища: бакет із щоденними дампами DS3 доступний за публічним посиланням — витік повної фінансової історії всіх користувачів.	конфіденційність
D-14	P2 API-шлюз	Denial of service	Надсилання пакетів синхронізації з десятками тисяч транзакцій без обмеження розміру тіла запиту й частоти: вичерпання CPU та пам’яті сервісу P3, недоступність синхронізації.	доступність
E-15	P3 Сервіс синхронізації	Elevation of privilege	IDOR: маршрут /accounts/{account_id}/transactions перевіряє лише дійсність JWT, але не належність рахунку; підстановка чужого account_id дає читання й зміну чужих транзакцій (горизонтальне підвищення привілеїв).	авторизація

Таблиця 5.2 – Розподіл загроз за категоріями STRIDE

Категорія	Кількість	Частка
Tampering	8	53 %

Категорія	Кількість	Частка
Spoofing	2	13 %
Information disclosure	2	13 %
Repudiation	1	7 %
Denial of service	1	7 %
Elevation of privilege	1	7 %

6 ОЦІНЮВАННЯ РИЗИКІВ

Для кожної загрози складено вектор CVSS v3.1 і обчислено базову оцінку калькулятором cvss.py. Пакетне оцінювання виконує допоміжний файл lab01_threat_model/scoring.py (лістинг і вивід — у додатку Б). Контрольний запуск калькулятора для вектора з методичних вказівок дав очікувані 9.8:

```
$ python cvss.py "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
базова оцінка: 9.8
```

Результати наведено в таблиці 6.1; рядки загроз високого ризику (оцінка ≥ 7,0) виділено жирним шрифтом.

Таблиця 6.1 – Оцінювання загроз за CVSS v3.1 та матрицею «ймовірність × вплив»

№	Вектор CVSS:3.1	Базова оцінка	Ймов.	Вплив	Ранг ризику
T-01	AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	6.8 (середній)	H	B	середній
T-02	AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N	5.5 (середній)	H	B	середній
T-03	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N	6.5 (середній)	C	C	середній
T-04	**AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N**	**7.5 (високий)**	**C**	**B**	**високий**
T-05	**AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H**	**8.8 (високий)**	**C**	**B**	**високий**
T-06	**AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N**	**8.1 (високий)**	**C**	**B**	**високий**
T-07	AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N	4.9 (середній)	H	C	низький
T-08	AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N	5.3 (середній)	H	C	низький
S-09	**AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N**	**7.4 (високий)**	**C**	**B**	**високий**
S-10	AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	6.1 (середній)	H	C	низький
R-11	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N	4.3 (середній)	C	H	низький
I-12	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	5.5 (середній)	H	B	середній
I-13	**AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N**	**7.5 (високий)**	**C**	**B**	**високий**

№	Вектор CVSS:3.1	Базова оцінка	Ймов.	Вплив	Ранг ризику
D-14	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H	6.5 (середній)	C	C	середній
E-15	**AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N**	**8.1 (високий)**	**C**	**B**	**високий**

Загроз високого ризику — 6 (T-05, T-06, E-15, T-04, I-13, S-09), що перевищує вимогу min_high_risk = 3. Ранги матриці узгоджуються з рівнями CVSS: усі шість загроз високого рівня CVSS отримали й ранг «високий». Найвищу оцінку (8,8) має загроза T-05 — її обрано для побудови дерева атак.

7 ДЕРЕВО АТАК ДЛЯ НАЙКРИТИЧНІШОЇ ЗАГРОЗИ

Корінь дерева — мета загрози T-05: несанкціонована зміна фінансових записів інших користувачів у хмарній БД. Кореневий вузол — AND: зловмисникові потрібні і автентифікований доступ до API, і можливість виконати довільний SQL.



Рисунок 7.1 – Дерево атак для загрози T-05

Найдешевший для порушника шлях — 1.1 AND 2.1: безкоштовна реєстрація плюс ін'єкція першого порядку, що не потребує ні модифікації клієнта, ні чужих облікових даних. Перекриття гілок контрзаходами з реєстру ризиків наведено в таблиці 7.1.

Таблиця 7.1 – Перекриття гілок дерева атак контрзаходами

Гілка	Контрзахід	Загроза в реєстрі
1.1	не перекривається (реєстрація відкрита за задумом)	—
1.2	зберігання токенів у Keystore, короткий TTL	I-12
1.3	rate limit, 2FA, перевірка зламаних паролів	S-09
2.1.1–2.1.3	параметризовані запити, allowlist для sort	T-05
2.1.2	узагальнені повідомлення про помилки	T-05
2.2.1	атестація клієнта, серверна валідація (КЗ-1)	T-06, T-03
2.2.2	параметризовані запити в генераторі звітів	T-05
усе дерево	RLS у PostgreSQL (КЗ-2): навіть успішний SQL не змінює чужі рядки	T-05, E-15

8 РЕЄСТР РИЗИКІВ І РІШЕННЯ

Реєстр (таблиця 8.1) впорядковано за спаданням базової оцінки CVSS. Для кожного ризику визначено стратегію оброблення, конкретний контрзахід і залишковий ризик після його впровадження; залишковий ризик у жодному рядку не перевищує вихідного.

Таблиця 8.1 – Реєстр ризиків

№	Ризик	Рішення	Контрзахід	Залишковий ризик
T-05 (8.8)	Зміна записів будь-яких користувачів через SQL-ін’єкцію	усунути	Параметризовані запити (ORM), allowlist допустимих значень для sort; Row-Level Security у PostgreSQL за owner_id (К3-2); роль БД без прав DDL; SAST-перевірка в CI.	низький
T-06 (8.1)	Підміна даних модифікованим клієнтом	зменшити + передати	Атестація клієнта (Play Integrity API / App Attest): сервер відхиляє запити неоригінальних збірок; обфускація R8; поширення лише через офіційні магазини (частину ризику передано модерації магазинів); серверна валідація всіх даних (К3-1).	середній — повністю виключити репакування неможливо, але К3-1 обмежує шкоду
E-15 (8.1)	Читання й зміна чужих рахунків (IDOR)	усунути	Централізована перевірка належності ресурсу в Р3: owner_id рахунку має збігатися з суб’єктом JWT (К3-1); RLS у DS3 як другий рубіж (К3-2).	низький
T-04 (7.5)	Фіктивні транзакції через підроблений webhook	усунути	Перевірка HMAC-SHA256 підпису зі спільним секретом, вікно часу ±5 хв, ідемпотентність за event_id; webhook — лише тригер, дані транзакції Р4 повторно запитує в банку через F11.	низький
I-13 (7.5)	Витік резервних копій	усунути	Блокування публічного доступу на рівні облікового запису хмари, шифрування SSE-KMS, сканування IaC-конфігурації в CI.	низький
S-09 (7.4)	Захоплення облікового запису	зменшити	Обмеження частоти спроб за обліковим записом та IP, 2FA (TOTP), перевірка пароля за базою зламаних паролів, сповіщення про вхід з нового пристрою.	низький
T-01 (6.8)	Зміна пакета синхронізації в транзиті	зменшити	TLS 1.3, certificate pinning (SPKI) у network_security_config, заборона користувацьких CA для домену API.	низький
T-03 (6.5)	Перезапис службових полів через mass assignment	усунути	Серверні DTO з allowlist полів; owner_id береться лише з JWT; balance_after обчислює сервер (К3-1).	низький

№	Ризик	Рішення	Контрзахід	Залишковий ризик
D-14 (6.5)	Відмова сервісу синхронізації	передати + зменшити	Захист від DDoS на рівні CDN/WAF провайдера (передача ризику); ліміт тіла запиту 1 МБ і 500 транзакцій у пакеті; rate limit на користувача.	низький
T-02 (5.5)	Зміна локальної БД на пристрої	зменшити	Шифрування БД SQLCipher із ключем в апаратному Keystore/Keychain, allowBackup=false; сервер перераховує баланси з транзакцій і не довіряє клієнтським підсумкам (КЗ-1).	низький
I-12 (5.5)	Розкриття токенів і ключів на пристрої	усунути	Зберігання в EncryptedSharedPreferences/Keychain, заборона логування токенів (lint-правило), access-токен на 15 хв із ротацією refresh-токена.	низький
T-08 (5.3)	Replay пакета синхронізації	усунути	UUID кожної зміни (ідемпотентність), версія запису з оптимістичним блокуванням, відхилення пакетів із застарілою версією.	низький
T-07 (4.9)	Знищення слідів у журналі аудиту	зменшити	Окрема роль лише з правом INSERT; хеш-ланцюг записів (кожен містить SHA-256 попереднього); щоденний експорт у WORM-сховище.	низький
S-10 (6.1)	Вхід у застосунок на викраденому пристрої	прийняти	Обґрунтування: потрібне фізичне заволодіння розблокованим пристроєм; застосунок не виконує платежів, тож збитки обмежені переглядом; блокування екрана ОС уже діє. Дешеві доповнення (6-значний PIN, затримка після 5 спроб) — у плані наступного релізу.	низький
R-11 (4.3)	Заперечення змін у спільному бюджеті	зменшити	Журнал змін спільного бюджету з author_id, device_id і позначкою часу в DS4; історія версій запису доступна всім учасникам.	низький

Частина контрзаходів діє одразу на кілька загроз (таблиця 8.2); їх доцільно впроваджувати першими.

Таблиця 8.2 – Наскрізні контрзаходи

Код	Контрзахід	Суть	Загрози
КЗ-1	Сервер — єдине джерело істини	серверна валідація схеми з allowlist полів, owner_id лише з JWT, перерахунок балансів на сервері, перевірка належності ресурсу	T-02, T-03, T-06, E-15
КЗ-2	Row-Level Security у PostgreSQL	політика owner_id = current_setting('app.user_id') на всіх таблицях з даними користувачів; навіть успішна ін’єкція чи IDOR не виходить за межі власних рядків	T-03, T-05, E-15

9 АНАЛІЗ РЕЗУЛЬТАТІВ

Розподіл загроз за категоріями STRIDE. Із 15 загроз 8 (53 %) належать до категорії Tampering, по 2 — до Spoofing та Information disclosure, по 1 — до Repudiation, Denial of service і Elevation of privilege. Гіпотезу варіанта підтверджено: підміна даних домінує і за кількістю, і за вагою — 3 з 6 загроз високого ризику (T-04, T-05, T-06) та загроза з найвищою оцінкою (T-05, 8.8) належать до Tampering. Причина — архітектурна: фінансові записи створюються на пристрої (МД1), який повністю контролює користувач чи зловмисник, і проходять через дві межі довіри, а ще одне джерело даних (webhook банку) входить у бекенд ззовні. Головний актив A1 має високу цінність саме за цілісністю: застосунок не виконує платежів, тому вартість атаки полягає у спотворенні фінансової картини.

Найвразливіші елементи діаграми. Найбільше загроз породив сервіс синхронізації P3 разом з його потоками F8 і F9: T-03, T-05, E-15 (усі три — високого або середнього ризику з I:H). Це перший довірений компонент, що приймає дані з недовіреної МД1, тож усі недоліки валідації концентруються в ньому. Друге місце посідає мобільний пристрій (МД1): P1, DS1, DS2 дали T-02, T-06, S-10, I-12, але ці загрози здебільшого вимагають локального чи фізичного доступу (AV:L/P), тому мають нижчі оцінки. Потоки F6/F7 і F10, що перетинають межі МД1 → МД2 та «зовнішня сутність» → МД2, дали T-01, T-08 і T-04. Отже, 9 з 15 загроз прив’язано до елементів на межах довіри або безпосередньо за ними.

Чому T-05 має найвищу оцінку. Для вектора AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H підоцінка експлуатованості дорівнює $8{,}22 \cdot 0{,}85 \cdot 0{,}77 \cdot 0{,}62 \cdot 0{,}85 \approx 2{,}84$, підоцінка впливу — $6{,}42 \cdot (1 - 0{,}44^3) \approx 5{,}87$, сума 8,71 після округлення вгору дає 8,8. Найбільший внесок дає вплив: SQL-ін’єкція порушує одразу всі три властивості (C, I, A = H), тоді як E-15 (8,1) не зачіпає доступність, а T-04 (7,5) — лише цілісність. Метрика AV:N (атака через інтернет) і PR:L (достатньо безкоштовної реєстрації) майже не знижують експлуатованість.

Контрзахід із найбільшим покриттям. Корінь дерева атак — вузол AND, тому параметризовані запити, що закривають гілку 2 (обидва варіанти ін’єкції),

зупиняють атаку повністю, хоча гілку 1 перекрити неможливо (реєстрація відкрита). Найширше покриття в реєстрі дають наскрізні контрзаходи: КЗ-1 «сервер — єдине джерело істини» знижує ризик Т-02, Т-03, Т-06 і Е-15, а КЗ-2 (Row-Level Security) — Т-03, Т-05 і Е-15 та обмежує наслідки будь-якої гілки дерева. Вони ефективніші за точкові заходи, бо діють на рівні довіреного компонента незалежно від того, як саме дані було підмінено на клієнті.

Прийняті ризики. Стратегію «прийняти» обрано лише для S-10 (6,1, ранг низький). Для повного усунення потрібен апаратно захищений окремий вхід із біометрією класу STRONG і віддаленим стиранням — це суттєві витрати на розроблення й підтримку, тоді як атака вимагає фізичного заволодіння розблокованим пристроєм, а збитки обмежені переглядом даних, бо застосунок не виконує платежів. Ризики D-14 і частково Т-06 передано провайдерам (CDN/WAF, магазини застосунків), де захист дешевший завдяки масштабу.

ВИСНОВКИ

1. Для мобільного застосунку обліку особистих фінансів FinTrack побудовано модель загроз: визначено 8 активів, DFD з 11 елементами, 14 потоками та 3 межами довіри, виявлено 15 загроз, з яких 8 належать до пріоритетної категорії Tampering.

2. Шість загроз мають базову оцінку CVSS ≥ 7,0 (T-05 — 8,8; T-06 і E-15 — 8,1; T-04 та I-13 — 7,5; S-09 — 7,4), що вдвічі перевищує мінімальну вимогу (3). Найкритичніша — SQL-ін’єкція в сервісі синхронізації T-05: віддалена атака з мінімальними привілеями, що порушує всі три властивості безпеки головного активу A1.

3. Першочергово слід усунути загрози T-05, E-15, T-03 і T-04 у бекенді: вони мають мережевий вектор, низьку складність і можуть бути закриті програмними змінами без участі користувача. Загрози на пристрої (T-02, I-12, S-10) мають нижчі оцінки через потребу в локальному чи фізичному доступі.

4. Найбільший ефект за найменших витрат дадуть два наскрізні контрзаходи: серверна валідація з перерахунком балансів (КЗ-1) і Row-Level Security у PostgreSQL (КЗ-2). Разом вони знижують ризик п’яти загроз (T-02, T-03, T-05, T-06, E-15) і перекривають усі гілки дерева атак. Після впровадження реєстру контрзаходів лише T-06 зберігає середній залишковий ризик, решта — низький.

Використання генеративних інструментів

Під час виконання роботи використано генеративний інструмент Claude як допоміжний засіб: для чернеткового формулювання описів загроз і контрзаходів та оформлення таблиць.

ДОДАТОК А

ЛІСТИНГ ДІАГРАМИ ПОТОКІВ ДАНИХ (DFD.MMD)

```
%% DFD: мобільний застосунок обліку особистих фінансів «FinTrack» (варіант 29).
%% Вигадана навчальна система. Позначення: ([...]) — зовнішня сутність,
%% [...] — процес, [(...)] — сховище даних, стрілка з підписом — потік даних.
flowchart TB
    E1([E1. Користувач]):::ext
    E2([E2. Open Banking API банку]):::ext

    subgraph TB1[Межа довіри 1: мобільний пристрій користувача]
        P1[P1. Мобільний застосунок]
        DS1[(DS1. Локальна БД SQLite)]
        DS2[(DS2. Сховище токенів і ключів)]
    end

    subgraph TB2[Межа довіри 2: хмарний бекенд]
        P2[P2. API-шлюз]
        P3[P3. Сервіс синхронізації]
        P4[P4. Сервіс імпорту транзакцій]
    end

    subgraph TB3[Межа довіри 3: зона зберігання даних]
        DS3[(DS3. Хмарна БД PostgreSQL)]
        DS4[(DS4. Журнал аудиту)]
        DS5[(DS5. Резервні копії)]
    end

    E1 -->|F1. транзакції, PIN, файл CSV| P1
    P1 -->|F2. баланси, звіти| E1
    P1 -->|F3. запис транзакцій| DS1
    DS1 -->|F4. читання транзакцій| P1
    P1 <-->|F5. токени, ключ БД| DS2
    P1 -->|F6. HTTPS: пакет синхронізації + JWT| P2
    P2 -->|F7. HTTPS: дельта змін| P1
    P2 -->|F8. автентифікований запит| P3
    P3 <-->|F9. SQL-запити| DS3
    E2 -->|F10. HTTPS webhook: нові транзакції| P4
    P4 -->|F11. OAuth2: запит виписки| E2
    P4 -->|F12. імпортовані транзакції| DS3
    P3 -->|F13. події аудиту| DS4
    P4 -->|F13. події аудиту| DS4
    DS3 -->|F14. щоденний бекап| DS5

    classDef ext fill:#eee,stroke:#333;
```

ДОДАТОК Б

ЛІСТИНГ SCORING.PY ТА РЕЗУЛЬТАТ ВИКОНАННЯ

```
# scoring.py — оцінювання переліку загроз (варіант 29:
# мобільний застосунок обліку особистих фінансів, пріоритет — Tampering)
from cvss import base_score

threats = {
    "T-01": "CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N",  # MITM пакета синхронізації
    "T-02": "CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N",  # зміна локальної SQLite
    "T-03": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N",  # mass assignment у
синхронізації
    "T-04": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N",  # підроблений webhook банку
    "T-05": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H",  # SQL-ін'єкція у фільтрі
    "T-06": "CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N",  # репакований APK
    "T-07": "CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N",  # зміна журналу аудиту
    "T-08": "CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N",  # replay пакета синхронізації
    "S-09": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N",  # credential stuffing
    "S-10": "CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N",  # обхід PIN на пристрої
    "R-11": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N",  # заперечення змін у спільному
бюджеті
    "I-12": "CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N",  # токени у відкритому вигляді
    "I-13": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N",  # публічний бакет із бекапами
    "D-14": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H",  # флуд великими пакетами
    "E-15": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N",  # IDOR через account_id
}


def level(score: float) -> str:
    if score == 0:
        return "немає"
    if score < 4.0:
        return "низький"
    if score < 7.0:
        return "середній"
    if score < 9.0:
        return "високий"
    return "критичний"


if __name__ == "__main__":
    for tid, vector in threats.items():
        s = base_score(vector)
        mark = "  <-- ВИСОКИЙ РИЗИК" if s >= 7.0 else ""
        print(f"{tid}  {vector}  {s:>4}  {level(s)}{mark}")
```

Результат виконання python scoring.py:

```
T-01  CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N   6.8  середній
T-02  CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N   5.5  середній
T-03  CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N   6.5  середній
T-04  CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N   7.5  високий  <-- ВИСОКИЙ РИЗИК
T-05  CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H   8.8  високий  <-- ВИСОКИЙ РИЗИК
T-06  CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N   8.1  високий  <-- ВИСОКИЙ РИЗИК
T-07  CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N   4.9  середній
T-08  CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N   5.3  середній
S-09  CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N   7.4  високий  <-- ВИСОКИЙ РИЗИК
S-10  CVSS:3.1/AV:P/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N   6.1  середній
R-11  CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N   4.3  середній
I-12  CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N   5.5  середній
I-13  CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N   7.5  високий  <-- ВИСОКИЙ РИЗИК
D-14  CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H   6.5  середній
E-15  CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N   8.1  високий  <-- ВИСОКИЙ РИЗИК
```

Репозиторій з артефактами роботи (threat_model.md, dfd.mmd, dfd.png, scoring.py):

https://github.com/Nikitos4443/Security_KPI/tree/main/Lab1